WeConnect 2.0 — Fix Retest Summary

Prepared for Lighthouse Communities Foundation
Date 21 October 2026

What we did

We retested the reported fixes independently, rather than by their status labels. We re-read the current source of all eighteen repositories, re-ran the automated checks against that source and the live backend, and rebuilt an isolated copy of the platform to re-run the write-side reproductions and the full probe battery. Every write was rolled back; no live or real data was touched.

What we found

Outcome	Findings
Confirmed fixed	The cross-centre *invoice* breach (an ordinary account is now refused); the disabled login guard; the stored-HTML (XSS) sink.
Improved	Mass assignment — 23 of 28 sites now guarded, up from about ten; the reset-code generator; one of the two publicly exposed API specifications closed.
Still open	The matching cross-centre *batch-close* breach, reproduced end to end; no control over status transitions; self-contradictory values still accepted; several endpoints return a server error on bad input or a success code on failure; the reset code is still written to the browser console; keys and configuration files remain committed; and CORS, security headers, error tracebacks and seven-day sessions are still live on `api-dev`.

One caveat worth deciding on

Several of the access fixes work only because staff accounts no longer carry the `System Manager` role — the underlying checks still exempt that role. If any account is given it again, those issues return for that account. How that role is granted is worth governing explicitly.

Where the detail is

The per-item status is in the bug tracker, in the *Today's Status* column. The items still open, grouped by root cause with the structural fix for each, are in the remediation plan.